PUZZLE ITC
changing IT for the better

# Chainguard Techlab

Christoph Raaflaub & Raphaela Seeger
raaflaub@puzzle.ch
seeger@puzzle.ch

# Schön euch kennen zu lernen




Raphaela Seeger

Platform Engineer

Solution Lead: Supply Chain Security

seeger@puzzle.ch





Christoph Raaflaub

Platform Architect

Member of the Technical Board

raaflaub@puzzle.ch


Alle Puzzlers

https://www.puzzle.ch/team

# Einführung zu Supply Chain Security

# Agenda

- Einführung
- Container und Cloud - eine sichere Lösung?
- Supply Chains: Probleme & Bedrohungen
- Warum ist jetzt Zeit zum Handeln?
- Lösungen: Supply Chain Security
- Start mit einer sicheren Quelle
- Chainguard Angebot



# Container und Cloud - Eine sichere Lösung?

# Wir arbeiten schon mit Containern und sicheren Plattformen, wozu noch Supply Chain Security?



Misconfigurations

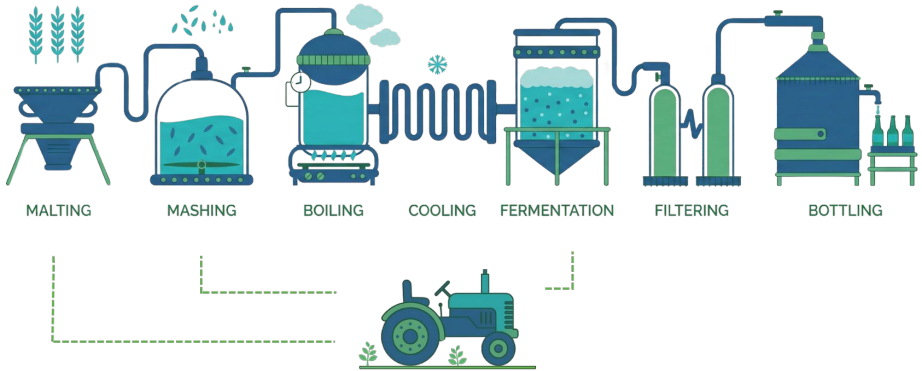
Supply Chain Attack Vectors

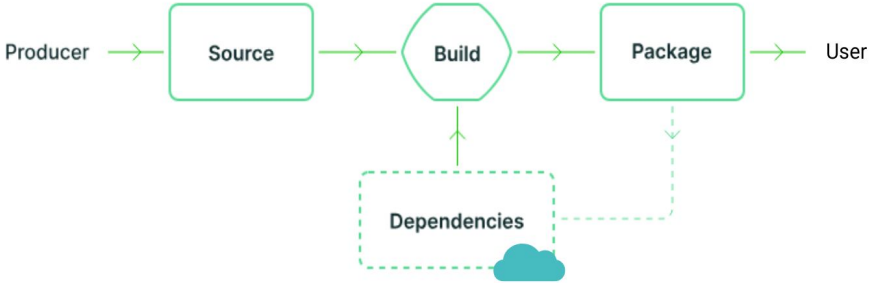
Most applications are based on Open Source.

- How credible are the maintainer?
- How secure is their supply chain?

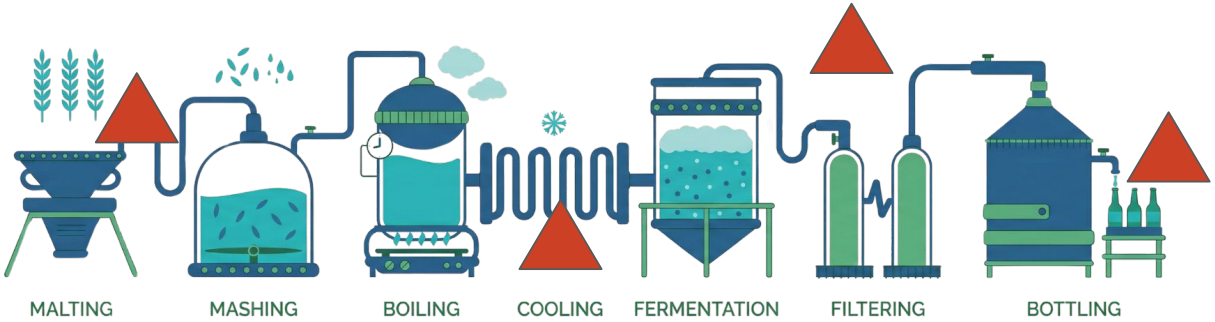
# Supply Chains
# Probleme & Bedrohungen

# Bier Brau Prozess vs Software Supply Chain



# Fehlerquellen beim Bierbrauen




Wrong beer filled in bottles

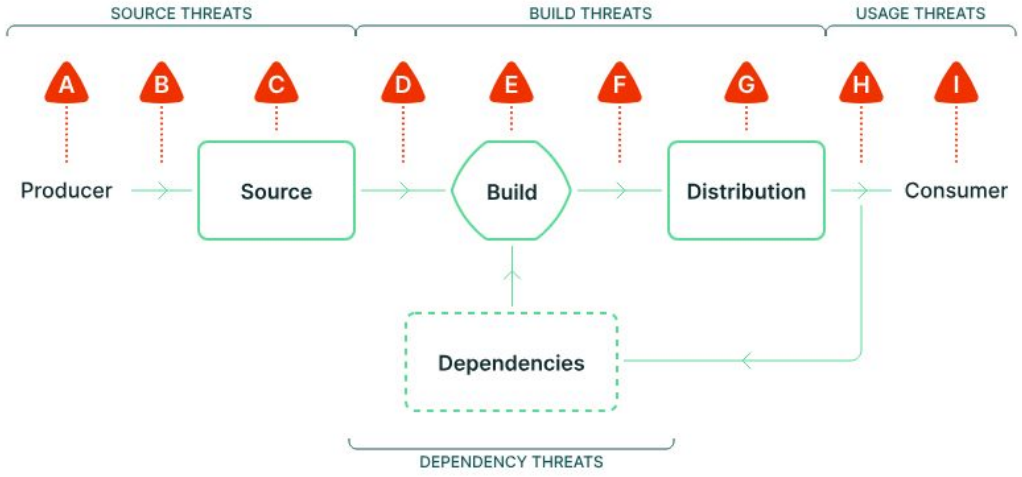
False labeling

Compromised/contaminated brewery

Wrong yeast was used

Wheat storage with mould contamination

# Fehlerquellen in der Supply Chain




A Producer (entity)
B Authoring & reviewing
C Source code management
D External build parameters
E Build process
F Artifact publication
G Distribution channel
H Package selection
I Usage

[SLSA: Software supply chain threats]

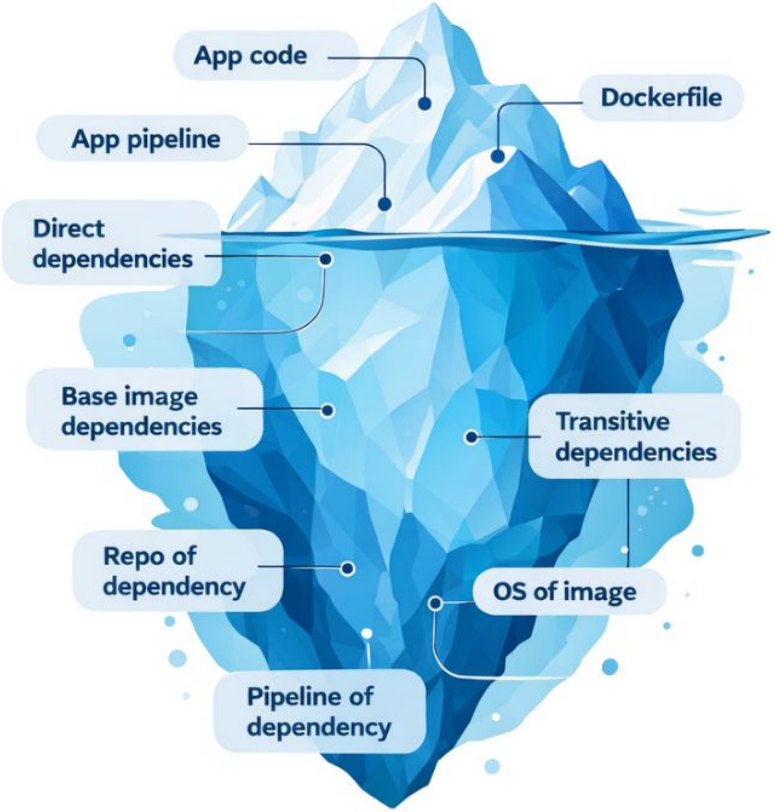
Usage Threats:
Unsecure transmission and wrong utilization

Build Threats:
Incorrect or hacked Build-process / -infrastructure

Dependency Threats:
Dependencies with vulnerabilities

Source Threats:
Source Repo compromised

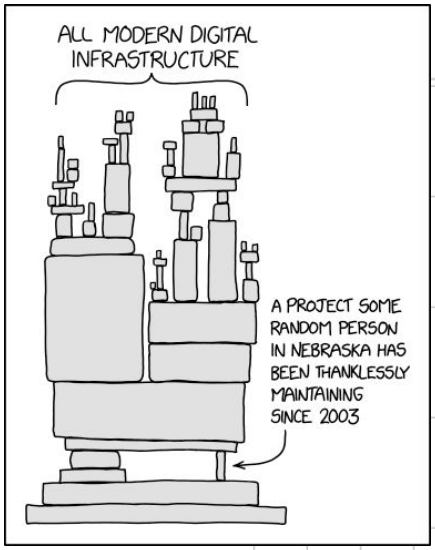
# Unsichtbare Dependencies - vergessene Aspekte



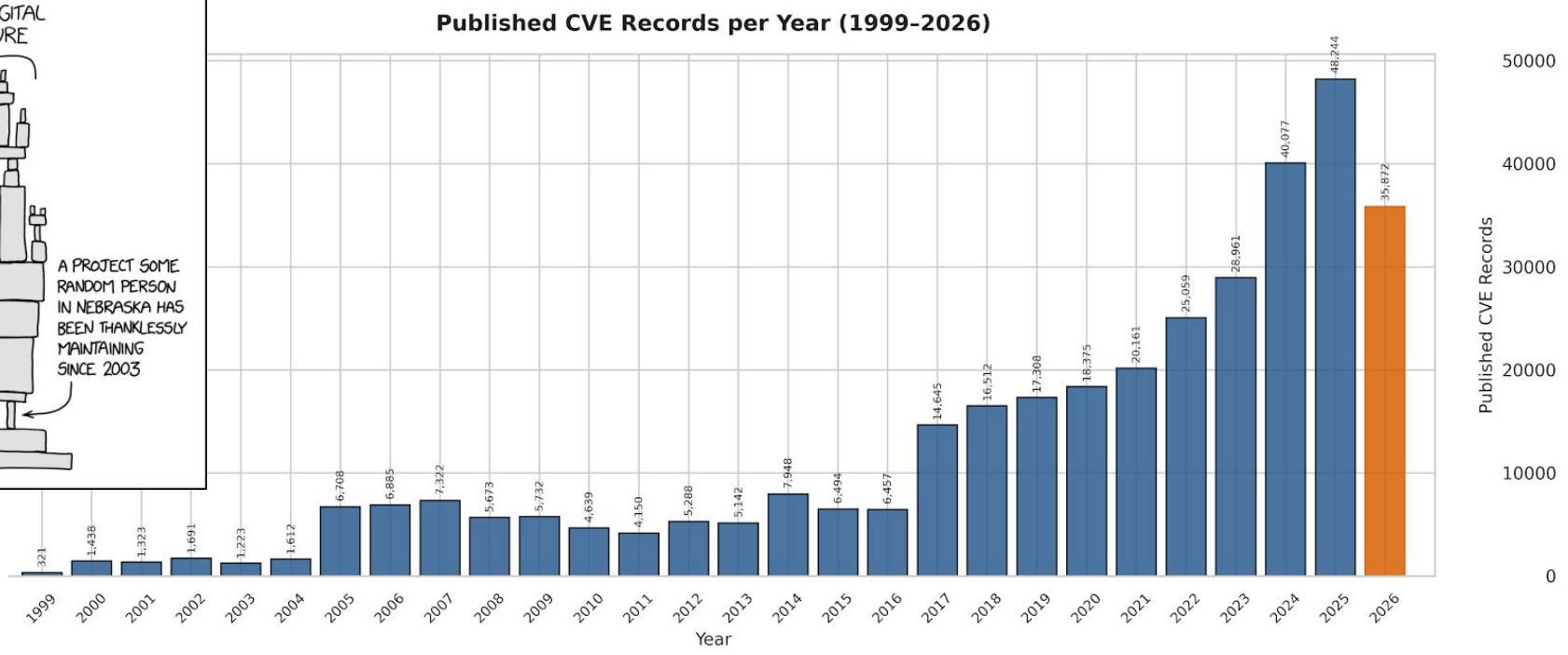



# Warum ist jetzt Zeit zum Handeln?

# Bedrohungen




xkcd: Dependencies




https://www.cve.org/About/Metrics

# Regulatorische Vorgaben



Payment Card Industry Data Security Standard (PCI DSS)



ISO 27001 certificates: Information security management

new



EU CRA: Supply Chain Purity Law

# EU Cyber Resilience Act — das Container Reinheitsgebot?



Vulnerability and Incident Reporting



Automatic Security Updates



Required SBOMs



Fines



# Lösungen
## Supply Chain Security

# Lösungsansätze



SLSA - Supply-chain Levels for Software Artifacts



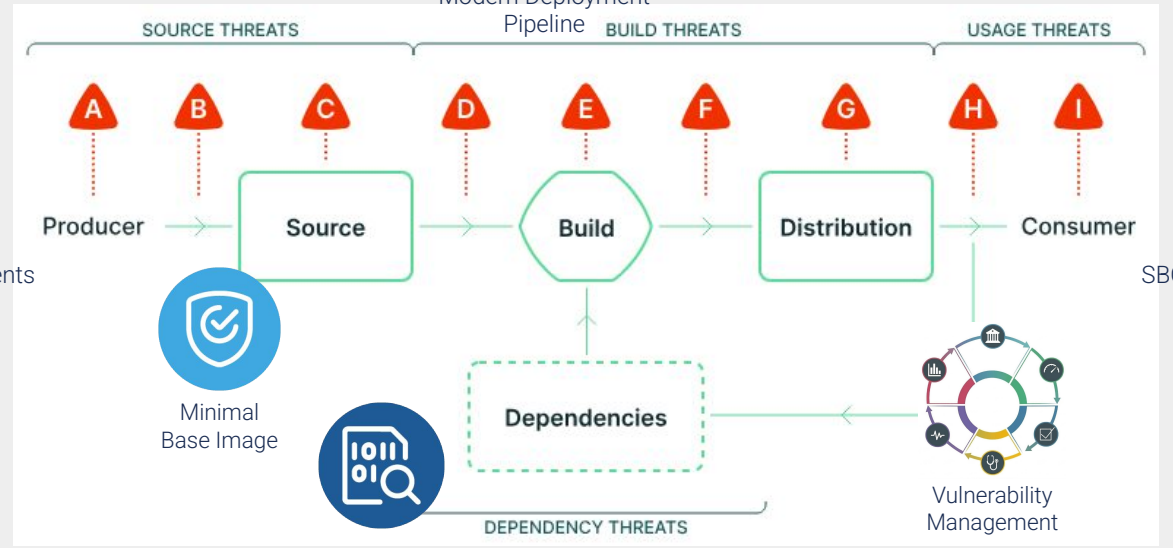
Secure Supply Chain Consumption Framework (S2C2F)



Modern Deployment Pipeline



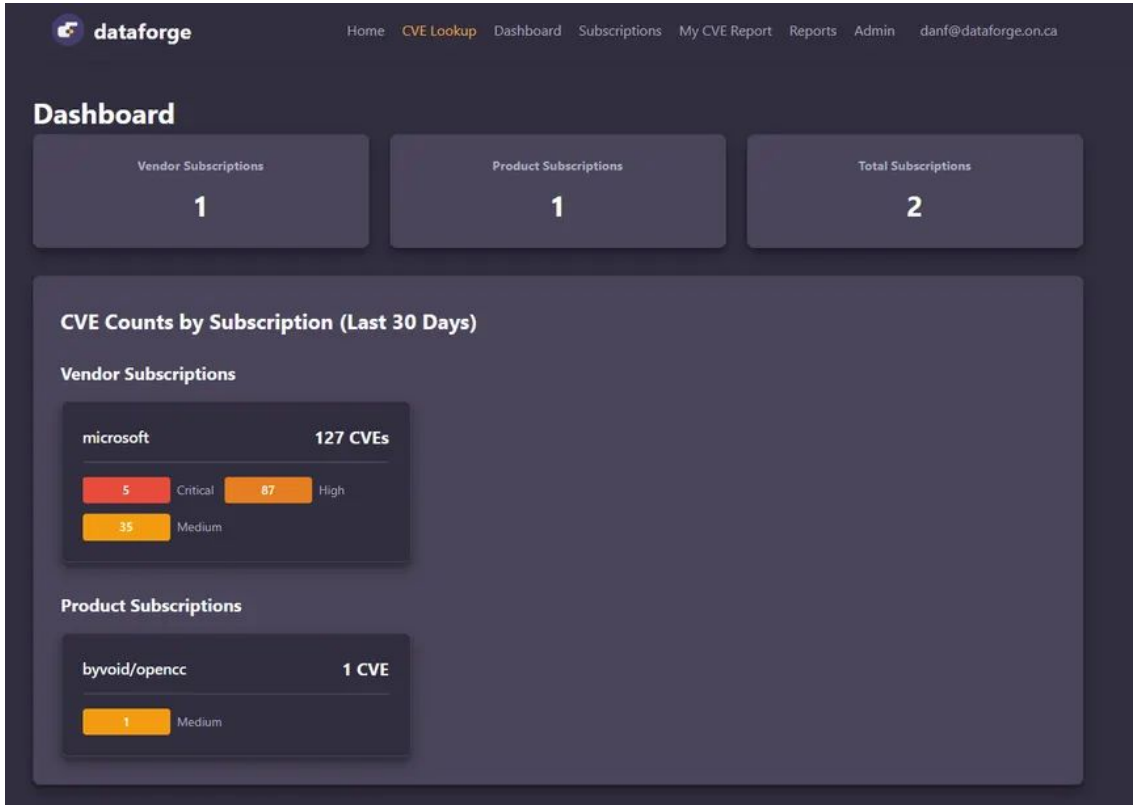
SBOM - table of contents



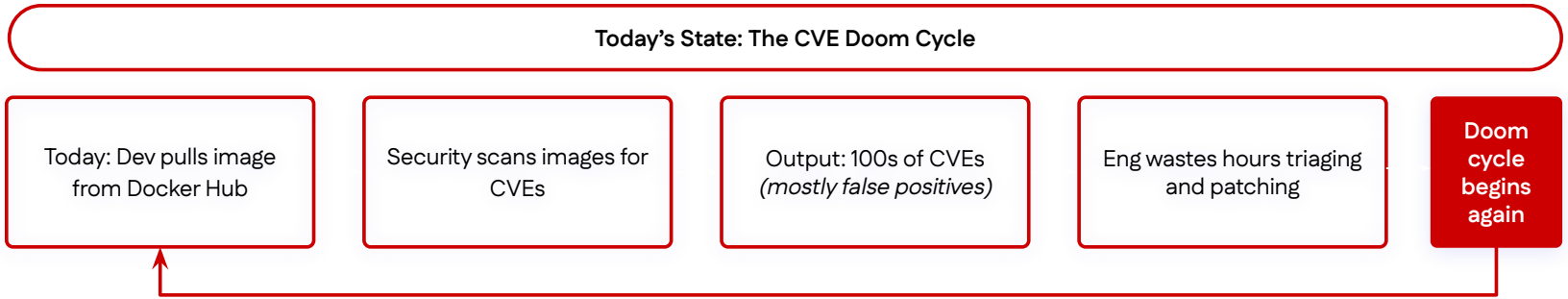



SBOM - table of contents

# Aber was machen wir bei ständig neuen Sicherheitslücken?



# Wie reduzieren wir tatsächlich CVEs?



# Vulnerability Management

## Solution drawbacks & challenges



Only surveillance / detection



Don’t fix underlying problem (orphaned Open Source Software)



No central solution



Expensive for companies -> engineers patch CVEs instead of coding



Exploited CVEs/ security loopholes cost money

# Start mit einer sicheren Quelle

# Opensource Software sicher benutzen




zero-CVE container images

# Puzzle & Chainguard Partnership



# Chainguard
# Angebot

# Chainguard Angebote



Minimal OS: Wolfi



0 CVE images



0 CVE helm charts



0 CVE libraries

# Fragen?

